

CyberTech A.Ş.

Risk Değerlendirme Raporu

Sızma Testi Öncesi Değerlendirme (Pre-Pentest)

Belge No	CT-RA-001
Sürüm	1.0
Hazırlama Tarihi	Nisan 2026
Kapsam	CyberTech A.Ş. - SOC Simülasyon Lab Ortamı
Hazırlayan	Arzum Enfal Kulaksız - SOC Analisti
Gizlilik	DAHİLİ - SINIRLI ERIŞİM

Risk Seviyesi Dağılımı

	Risk Seviyesi	Sayı	Yüzde
	KRİTİK	5	33%
	YÜKSEK	6	40%
	ORTA	4	27%
	DÜŞÜK	0	0%

Sızma testi öncesinde tespit edilen KRİTİK ve YÜKSEK seviyeli riskler.

Bu çalışma kitabı 6 sekmeden oluşur: Özet, Risk Matrisi, Varlık Envanteri, Tehdit Kataloğu, Zafiyet Kataloğu, Risk Kayıt Defteri, Eylem Planı, Pentest Eşleştirme.

5x5 Risk Matrisi (Olasılık x Etki)

Risk Skoru = Olasılık x Etki. Renk: Kırmızı=KRİTİK/YÜKSEK, Turuncu=ORTA, Yeşil=DÜŞÜK

Olasılık ↓ / Etki →	Çok Düşük (1)	Düşük (2)	Orta (3)	Yüksek (4)	Çok Yüksek (5)
Çok Yüksek (5)	5	10	15	20	25
Yüksek (4)	4	8	12	16	20
Orta (3)	3	6	9	12	15
Düşük (2)	2	4	6	8	10
Çok Düşük (1)	1	2	3	4	5

Skor Aralığı

20–25

13–19

6–12

1–5

Seviye

KRİTİK

YÜKSEK

ORTA

DÜŞÜK

Müdahale Süresi

Derhal müdahale (≤ 24 saat)

Acil önlem (≤ 1 hafta)

Planlı iyileştirme (≤ 1 ay)

İzleme ve kabul (≤ 3 ay)

Varlık Envanteri ve CIA Kritikoloji Değerlendirmesi

ID	Varlık	Tür	Bölge	Gizlilik	Bütünlük	Erişilebilirlik	Genel CIA
V-01	Router / Ağ Cihazı	Ağ	Perimeter	Orta	Orta	Orta	Orta
V-02	SIEM Sunucusu (Wazuh)	Sunucu	İç Ağ	Yüksek	Yüksek	Yüksek	Yüksek
V-03	Windows 10 İş İstasyonu	Endpoint	İç Ağ	Yüksek	Orta	Orta	Orta
V-04	Web Uygulama Sunucusu (Metasploitable 2)	Sunucu	İç Ağ*	Kritik	Yüksek	Orta	Yüksek
V-05	Veritabanı Sunucusu	Sunucu	İç Ağ	Kritik	Kritik	Kritik	Kritik
V-06	IDS/IPS Sunucusu (Suricata)	Sunucu	İç Ağ	Yüksek	Yüksek	Yüksek	Yüksek

* Teoride DMZ olmalıydı.

Tehdit Katalođu (Threat Catalog)

Tehdit ID	Tehdit Kategorisi	Tehdit Kaynađı	Hedef Varlık(lar)	MITRE ATT&CK
T-01	Ađ Keşfi / Port Tarama	Dıř saldırgan, iç tehdit	Tüm sistemler	T1046, T1595
T-02	Kaba Kuvvet (Brute-Force)	Dıř saldırgan	V-03, V-04	T1110
T-03	Bilinen CVE İstismarı	Dıř saldırgan, APT	V-04 (vsftpd)	T1190
T-04	SQL Enjeksiyonu	Dıř saldırgan, web	V-04, V-05	T1190
T-05	Kimlik Bilgisi Dökümü	Saldırgan (post-exploit)	V-03	T1003
T-06	Hash Aktarımı (Pass-the-Hash)	Saldırgan (post-exploit)	V-03	T1550.002
T-07	Yanal Hareket	Saldırgan (post-exploit)	V-03, V-04	T1021
T-08	Veri Sızdırma (Exfiltration)	Dıř saldırgan, iç tehdit	V-04, V-05	T1041
T-09	Savunmayı Atlatma	Geliřmiř saldırgan	V-03	T1562
T-10	Fidye Yazılımı	Siber suç örgütü	Tüm sistemler	T1486
T-11	SIEM/IDS Kır Noktaları	Saldırgan (sessiz)	V-02, V-06	T1562.001
T-12	İçeriden Tehdit	Yetkili kullanıcı	V-05	T1078

Zafiyet Katalođu (Vulnerability Catalog)

Zafiyet ID	Zafiyet	Etkilenen Varlık	CVE / Referans	CVSS
Z-01	vsftpd 2.3.4 Arka Kapısı	V-04 (MS2)	CVE-2011-2523	10.0 (Kritik)
Z-02	SMB EternalBlue / MS17-010	V-03 (Win10)	CVE-2017-0144	9.3 (Kritik)
Z-03	Ađ Segmentasyonu Eksikliđi	Tüm ađ	CIS Control 12	N/A (Yapısal)
Z-04	Hesap Kilitleme Politikası Eksik	V-03	CIS Control 5	N/A (Yapısal)
Z-05	SAM/LSA Hash Depolaması	V-03	MS KB2871997	7.8 (Yüksek)
Z-06	SMB İmzalama Devre Dışı	V-03	CVE-2017-0145	8.1 (Yüksek)
Z-07	DVWA SQL Injection	V-04 (DVWA)	OWASP A03	8.8 (Yüksek)
Z-08	Eski Şifreleme Algoritmaları (SSH)	V-04	NIST SP 800-131A	6.5 (Orta)
Z-09	Varsayılan/Zayıf Şifre Kullanımı	V-03, V-04	CIS Control 5	N/A (Yapısal)
Z-10	SIEM Kural Eksikliđi (PtH, Exfil.)	V-02	MITRE D3FEND	N/A (Yapısal)

Risk Kayıt Defteri (Risk Register)

Risk Skoru = Olasılık × Etki (otomatik hesaplanır). Sütun başlıklarına tıklayarak filtreleyebilirsiniz.

Risk ID	Tehdit	Zafiyet	Varlık	Olasılık (1-5)	Etki (1-5)	Skor	Seviye	Sahibi
R-01	Ağ Keşfi	Z-03 Segmentasyon Eksikliği	Tüm ağ	5	4	20	KRİTİK	SOC Ekibi
R-02	vsftpd CVE İstismarı	Z-01 Backdoor	V-04	5	5	25	KRİTİK	BT Güvenlik
R-03	SQL Enjeksiyonu	Z-07 DVWA SQLi	V-04/V-05	4	5	20	KRİTİK	BT Güvenlik
R-04	Fidye Yazılımı	Z-03, Z-04	Tüm ağ	4	5	20	KRİTİK	CISO
R-05	Brute-Force (SSH/SMB)	Z-04 Kilitleme Yok	V-03	5	4	20	KRİTİK	BT Yönetici
R-06	Kimlik Bilgisi Dökümü	Z-05 SAM/LSA	V-03	4	4	16	YÜKSEK	BT Altyapı
R-07	Pass-the-Hash	Z-05, Z-06 SMB Signing	V-03	4	4	16	YÜKSEK	BT Altyapı
R-08	Yanal Hareket	Z-03, Z-06	V-03/V-04	3	5	15	YÜKSEK	Ağ Ekibi
R-09	Veri Sızdırma	Z-03, Z-07	V-04/V-05	3	5	15	YÜKSEK	BT Güvenlik
R-10	Savunmayı Atlatma	Z-09, Z-10	V-03	4	4	16	YÜKSEK	SOC Analisti
R-11	EternalBlue (SMB)	Z-02 MS17-010	V-03	3	5	15	YÜKSEK	BT Yönetici
R-12	SIEM Kör Noktaları	Z-10 Kural Eksikliği	V-02	4	3	12	ORTA	SOC Analisti
R-13	İçeriden Tehdit	Z-09 Zayıf Şifre	V-05	2	5	10	ORTA	CISO
R-14	Eski SSH Algoritmaları	Z-08	V-04	3	3	9	ORTA	BT Altyapı
R-15	Yetkisiz Fiziksel Erişim	Fiziksel Kontrol Yok	V-02	2	3	6	ORTA	Tesis Yönetimi

Notlar
Tüm ağ tek /24 alt ağda, DMZ ayrımı yok
CVE-2011-2523, doğrudan root erişimi
Union/error-based; müşteri DB riski
Segmentasyon yokluğu yayılmayı kolaylaştırır
Hesap kilitleme politikası uygulanmıyor
LSASS/SAM dump mümkün
SMB signing kapalı
Segmentasyon eksikliği nedeniyle kolaylaşıyor
DB'ye SQLi üzerinden erişim + çıkış kısıtı yok
PowerShell obfuscation, Defender bypass
Yamasız SMBv1 servis
PtH/Exfil/Evasion için özel kural yok
Yetkili kullanıcı kötüye kullanımı riski
Zayıf şifreleme, MitM riski
Sunucu odası erişim kontrolü zayıf

Kontrol Önerileri ve Eylem Planı

Öncelik sırasına göre gruplandırılmıştır.

Risk ID	Öncelik	Önlem	Sorumlu	Başarı Kriteri	Süre
R-01	KRİTİK	Ağ segmentasyonu: DMZ ile iç ağı VLAN ile ayır	BT Altyapı	Metasploitable → Windows doğrudan erişim yok	≤ 1 hafta
R-02	KRİTİK	vsftpd 2.3.4 yamala veya servisi kapat	BT Güvenlik	Açık port 21 kapatılmış / güncel sürüm	≤ 1 hafta
R-03	KRİTİK	Web Uygulama Güvenlik Duvarı (WAF) etkinleştir; DVWA'yı kapat	BT Güvenlik	SQLi payload'ları engelleniyor	≤ 1 hafta
R-05	KRİTİK	Windows GPO: 5 başarısız deneme = 30 dk kilit uygula	BT Yönetici	AD kilitleme politikası aktif	≤ 1 hafta
R-04	KRİTİK	Offline yedekleme ve fidye yazılımı kurtarma planı oluştur	BT / CISO	Yedek testi başarılı (RTO ≤ 4 saat)	≤ 1 hafta
R-06	YÜKSEK	SAM/LSA kimlik bilgisi koruması (Credential Guard) etkinleştir	BT Altyapı	LSASS dump engelleniyor	≤ 1 ay
R-07	YÜKSEK	SMB imzalamayı zorunlu hale getir (RequireSecuritySignature=1)	BT Altyapı	Signing: True görünüyor	≤ 1 ay
R-08	YÜKSEK	Ağ erişim kontrolü — kaynak MAC/IP tabanlı segmentasyon	Ağ Ekibi	Yanal hareket kısıtlı	≤ 1 ay
R-10	YÜKSEK	PowerShell script block logging + AMSI etkinleştir	BT Güvenlik	Obfuscated payload Wazuh'ta tespit ediliyor	≤ 1 ay
R-11	YÜKSEK	MS17-010 yaması uygula (KB4012212)	BT Yönetici	Wazuh zafiyet taraması: temiz	≤ 1 ay
R-09	YÜKSEK	DB erişimine ek şifreleme + DLP kontrolü ekle	BT Güvenlik	Veri sızdırma testinde engelleniyor	≤ 1 ay
R-12	ORTA	PtH, Exfiltration, Defense Evasion için Wazuh özel kuralları yaz	SOC Analisti	Alert tetikleniyor (pentest ile doğrulanır)	≤ 3 ay
R-13	ORTA	MFA tüm ayrıcalıklı hesaplara zorunlu hale getirilsin	BT / CISO	AD'de MFA kaydı %100	≤ 3 ay
R-14	ORTA	SSH eski algoritmaları devre dışı bırak (yalnız Ed25519/AES-256)	BT Altyapı	SSH config: eski algoritma yok	≤ 3 ay
R-15	ORTA	Sunucu odası fiziksel erişim kontrolü gözden geçir	Tesis Yönetimi	Kart/PIN erişim sistemi mevcut	≤ 3 ay

Risk – Sızma Testi Eşleştirme Tablosu

Risk değerlendirmesindeki bulguların sızma testi faz ve INC numaralarıyla ilişkilendirilmesi.

Risk ID	Pentest Fazı	Olay No	Beklenen Sonuç
R-01	Faz 1 — Keşif	INC-006	Nmap taramaları Wazuh/Suricata'da tespit edilmeli
R-05	Faz 2 — İlk Erişim	INC-007	Hydra brute-force Wazuh Rule 100026 tetiklemeli
R-11	Faz 2 — İlk Erişim	INC-008	EternalBlue girişi tespit edilmeli (patch başarısı)
R-06	Faz 3 — Kimlik Erişimi	INC-010	SAM/LSA dump Wazuh'ta görünmeli
R-07	Faz 4 — Yanal Hareket	INC-011	PtH NTLM Remote Logon uyarısı üretmeli
R-02	Faz 5A — MS2 Exploit	INC-012	vsftpd backdoor Suricata Rule 100047 ile tespit edilmeli
R-09	Faz 5A — Sızma Sonrası	INC-013	/etc/shadow indirme Wazuh'ta GPL ATTACK_RESPONSE göstermeli
R-03	Faz 5C — SQLi	INC-015	DVWA SQLi Suricata Rule 100050/100051 tetiklemeli

Not: Tespit edilen INC sayısı bu tablodaki beklenti sayısı ile eşleşiyorsa SOC görünürlik kapasitesi doğrulanmış demektir.